

黑客环伺！12个国家级APT组织紧盯我国

奇安信威胁情报中心 今天

以下文章来源于虎符智库，作者红雨滴团队



虎符智库

“虎符智库”专注解读网络安全重大事件与技术趋势，提供高层决策参考。

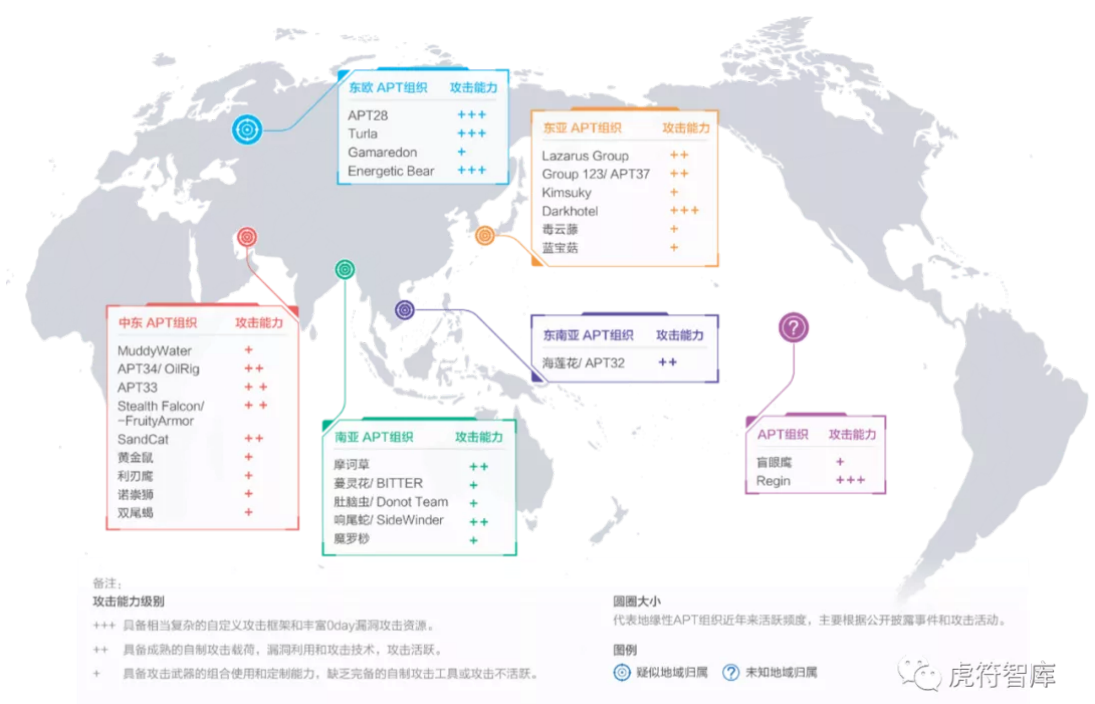


本文 7513字 阅读约需 22分钟

国家级APT（Advanced Persistent Threat，高级持续性威胁）组织是有国家背景支持的顶尖黑客团伙，专注于针对特定目标进行长期的持续性网络攻击。

2021 年上半年，网络武器威力和攻击规模持续增大，可能是近年来APT攻击活动最黑暗的半年。全球 APT 组织为达到攻击目的，不惜花费巨额资金和人力成本，使用的在野0day 漏洞数量陡然剧增，出现的频次之高为历年罕见。

在新冠疫情、地缘政治等复杂背景下，针对我国的高级威胁持续不断。2021 年上半年，毒云藤、蔓灵花、海莲花等国家级攻击组织，持续针对我国境内开展攻击活动。奇安信威胁情报中心近期盘点来针对我国的全球 APT 组织。



一、南亚篇

// 1、摩诃草 (APT-Q-36)



威特智库

【组织概述】

摩诃草组织是 Norman 2013 年披露并命名的APT 组织。其最早攻击活动可以追溯到 2009 年11 月， 该组织主要针对中国、巴基斯坦等亚洲地区和国家进行网络间谍活动。

在针对中国地区的攻击中，主要针对政府机构、科 研教育领域进行攻击。具有 Windows、Android、Mac OS 多系统攻击的能力。

【攻击事件】

2018 年春节前后，某政府单位收到一些带有恶意 下载链接的钓鱼邮件，邮件内容与其工作相关，一旦目 标用户下 载并打开 office 文档，则会触发漏洞 CVE- 2017-8570 并执行恶意脚本，最终下载远控木马导致 主机被控。

此外，摩诃草组织在本次攻击活动中注册了大量与 我国敏感单位 / 机构相关的相似域名， 以对我国特定的领 域进行 定向攻击。

奇安信威胁情报中心通过对此次攻击 活动中大量网络资产分析发现，其中一个 IP 地址曾在摩 诃草历史的攻击活动 中被披露使用，因此将此次攻击的幕后团伙判定为摩诃草 APT 组织。

// 2、蔓灵花 (APT-Q-37)



威特智库

【组织概述】

蔓灵花(Bitter)最早由国外安全厂商 Forcepoint 于 2016 年命名。研究人员发现其 RAT 变种在进行网络 通信时往 往包含有“BITTER”字符，故将行动命名为 BITTER。该组织至少自 2013 年 11 月开始活跃，长期 针对中国及巴基斯坦 的政府、军工、电力、核等部门发动网络攻击，窃取敏感资料。

【攻击事件】

2018 年 1 月，某工业大厂员工收到一份钓鱼邮件，邮件声称来自该厂信息技术中心，提醒员工邮件账户登录异常，并要求员工通过“安全链接”验证邮件账户。该“安全链接”为高度仿造的企业邮箱登录页面，目标用户在此页面输入账号密码后将被攻击者收集用于向帐户内的其他用户发送带有病毒附件的邮件。附件被执行后将导致机器被种植后门木马。

奇安信威胁情报中心通过对钓鱼链接的域名跟踪分析，发现国内疑似被攻击的组织机构还包括中国 XXXX 集团有限公司、中国 XX 对外工程有限公司以及 XXXXXX 大学。

经过关联分析，奇安信威胁情报中心发现此次攻击活动中伪装成 JPG 图片的恶意样本释放的诱饵图片与蔓灵花组织在 2016 年的攻击活动中所使用的诱饵图片完全一致。此外，此次攻击活动发现的后门程序中查找 avg 杀软的相关代码片段与蔓灵花组织使用的相关代码片段也存在高度相似性。因此将此次攻击活动判定为蔓灵花 APT 组织所为。

3、魔罗杪(APT-Q-39)



【组织概述】

Confucius 组织是 Palo Alto Networks Unit 42 于 2017 年 10 月发现的攻击团伙，该团伙主要使用网络钓鱼邮件针对巴基斯坦目标实施攻击。

2017 年末趋势命名 Confucius 为 APT 组织，并分析了其与 Patchwork 存在一些联系。趋势科技表示，至少从 2013 年就发现该组织活跃，使用 Yahoo! 和 quora 论坛作为 C&C 控制器，该组织可能来自于南亚。该组织拥有对 Windows, Android 的攻击恶意代码，并常用 Delphi 作为其 Dropper 程序。

从奇安信威胁情报中心内部的威胁情报数据分析来看，这两个组织可以通过相似的 Delphi Dropper 程序使用的控制域名联系到一起。但其与摩诃草的主要不同在于攻击目标主要以巴基斯坦和印度为主，并通常伪装成俄罗斯的来源。

APT-Q-39 属于攻击境内目标的境外组织，奇安信威胁情报中心对 APT-Q-31 组织的命名为魔株系——魔罗杪，“魔罗”出自该组织的地域教派神话，意为乱人事者。“杪”则象征该组织的地缘及文化特征。

【攻击事件】

2020 年 9 月，奇安信威胁情报中心披露了来自南亚地区的定向攻击：提菩行动。在此次活动中，攻击者使用了多种攻击手法例如：钓鱼邮件 + 钓鱼网站、钓鱼邮件 + 恶意附件、木马文件投放、安卓恶意软件投放，其中还包括部分商业、开源木马的使用以增加分析人员的溯源难度。

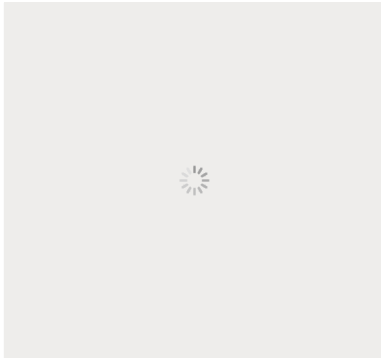
通过对提菩行动的攻击目标侧分析发现，此次攻击活动主要针对中国、巴基斯坦、尼泊尔等地的航空航天技术部门、船舶工业、核工业（含核电）、商务外贸、国防军工、政府机关（含外交）、科技公司。其主要目的为窃取特定国家的核心国防军工技术。

奇安信威胁情报中心红雨滴团队基于内部大数据平台，对此次攻击活动中使用的恶意软件分析后发现， AsyncRat 回连的C2可关联到多个魔罗杪组织曾用特马，且部分样本曾被用于针对巴基斯坦缉毒部的攻击 中。

此外，研究人员还追踪到此次攻击活动中的SFX类型样本与魔罗杪历史针对巴基斯坦WIL兵工厂活动中的样本同源。因此，奇安信对此次活动背后的组织判别为境外APT 组织魔罗杪。

二、东南亚篇

4、海莲花(APT-Q-31)



【组织概述】

海莲花组织是奇安信于 2015 年披露并命名的APT 组织。该组织自 2012 年 4 月起，针对中国政府、 科研院所、海事机构、海域建设、航运企业等相关重要领域展开了有组织、有计划、有针对性的长时间不间断攻击。

APT-Q-31 属于攻击境内目标的境外组织，奇安信威胁情报中心对 APT-Q-31 组织的命名为魔株系——海莲花，“莲花”是表现了该组织的地缘及文化特征，“海”则主要表现了该组织以海洋领域为主要攻击目标的活动特征。

【攻击事件】

2020 年 12 月，奇安信态势感知与安全运营平台(NGSOC)在客户侧发现多台终端电脑与特定端口进 行数据交互，研究人员在对交互数据分析后发现绑定在 该端口通信的协议是一个没有验证加密的私有协议，对 该协议数据进行逆向解密之后发现这是一些高危的指令，如修改管理员密码。

在经过层层分析和定位之后，奇安信研究人员发现这是一起供应链攻击，攻击者通过在安全终端管理软件 中植入一段恶意代码，使得 18 年 9 月份之后的安全终端管理软件版本均有该代码块，且安装文件带有厂商数字签名。内网中任意 IP 的机器均可无需验证向安装了该终 端软件的机器发送命令并执行。

这种源代码污染供应链攻击非常隐蔽，奇安信天擎在 2020 年12 月更新病毒库之后扫描出了所有被植入木马的终端设备，经过供给链还原最终确认此攻击事件的 发起组织为海莲花。

三、东亚篇

5、Darkhotel(APT-Q-10)



【组织概述】

Darkhotel组织是Kaspersky2014年披露的APT组织。该组织主要针对国防工业基地、军事、能源、政府、非政府组织、电子制造、制药和医疗等部门的公司高管、研究人员和开发人员。其因擅长使用酒店网络跟踪和打击目标而得名。

【攻击事件】

2019年7月，攻击者针对国内多个重点单位网络资产进行信息收集，通过Web漏洞入侵暴露在互联网上的内部系统后台登录页面并植入IE 0day漏洞以构造水坑攻击，相关单位网站管理员访问后台页面触发漏洞并被植入木马后门导致计算机被控、机密信息泄漏。

2020年2月，奇安信威胁情报中心红雨滴团队监测到上述多个重点单位的内部系统管理登录页面被植入恶意代码以执行水坑攻击。研究人员在深入分析被植入的代码后，确认此次事件背后的攻击团伙为境外APT组织Darkhotel。

通过奇安信威胁情报中心大数据关联分析后发现，攻击者使用的微软IE浏览器漏洞CVE-2019-1367利用代码在2019年7月19日就被上传至被攻击的服务器，而该漏洞微软在2019年9月份才修补，因此在攻击发生的当时漏洞还处于0day漏洞状态，研究人员推断，Darkhotel最晚在2019年7月就利用0day漏洞对我国执行了针对性的攻击。

6、虎木槿(APT-Q-11)

【组织概述】

虎木槿是疑似来自东北亚的APT组织，使用的恶意代码有着很强的隐蔽性，且具备0day漏洞发掘利用能力，曾通过浏览器漏洞攻击国内重点单位。2019年，奇安信捕获境外APT组织虎木槿针对国内核心教育科研政府机构的攻击活动并将活动命名为“幻影”行动。

“幻影”行动意指虚幻而不真实的影像，取意于攻击者在浏览器漏洞利用过程中通过播放不存在的Windows Media Video影音文件来启动MediaPlayer插件，从而劫持执行下载的恶意DLL以达到执行木马获取控制的目的，体现了攻击者变幻莫测的攻击技巧和高超的技术能力。

APT-Q-11属于攻击境内目标的境外组织，奇安信威胁情报中心对APT-Q-11组织的命名为魔株系——虎木槿。“虎”与“木槿”均取自该组织地缘文化象征。

【攻击事件】

2019年，奇安信威胁情报中心红雨滴团队结合天眼产品在客户侧的部署检测，在全球范围内率先监测到多例组合使用多个浏览器高危漏洞的定向攻击。此次活动目标包括多个国内核心教育科研政府机构和个人，被攻击目标只需使用某浏览器低版本打开网页就可能中招，被黑客植入后门木马甚至完全控制电脑。

7、毒云藤(APT-Q-20)



【组织概述】

毒云藤组织是奇安信于 2015 年 6 月首次披露的疑似有我国台湾地缘背景的 APT 组织，其最早的活动可以追溯到 2007 年。该组织主要针对国内政府、军事、国防、科研等机构，使用鱼叉邮件攻击和水坑攻击等手段来实施 APT 攻击。

APT-Q-20 属于攻击境内目标的境外组织，奇安信威胁情报中心对 APT-Q-20 组织的命名为魔株系——毒云藤。“毒藤”意为该组织在多次攻击行动中，都使用了 Poison Ivy(毒藤)木马，“云”字取于该组织在中转信息时，曾使用云盘作为跳板传输资料。

【相关事件】

2020 年 10 月，奇安信披露了华语情报搜集活动：血茜草行动。从 2018 年至 2020 年，毒云藤组织利用大陆最常用的社交软件、邮箱系统、以及政府机构网站、军工网站、高等院校网站等进行了大规模的仿制，目的是尽可能多地获取目标的个人信息，为后续窃取我国情报信息做准备。

攻击主要分为钓鱼网站攻击以及钓鱼邮件攻击。在钓鱼邮件攻击中，毒云藤主要伪装成多种具有鲜明特色的角色如智库类目标、军民融合产业园、军事杂志、公务员类猎头公司等。

经过关联分析，奇安信威胁情报中心发现，此次攻击活动中使用的恶意代码同历史攻击活动一样利用 WinRAR ACE 漏洞 CVE-2018-20250 进行下发，且恶意代码中所使用的 API 函数以及使用 strrev 函数将字符串反序的特点也与历史代码几乎一致，最后木马回连的 C2 解析出的 IP 反查可得部分血茜草钓鱼网站域名。至此研究人员判定此次攻击活动与毒云藤组织相关。

// 8、蓝宝菇 (APT-Q-21)



【组织概述】

蓝宝菇 (APT-C-12) 是奇安信率先公开和披露的 APT 组织。该组织从 2011 年开始持续至今，对我国政府、军工、科研、金融等重点单位和部门进行了持续的网络间谍活动。蓝宝菇 (APT-C-12) 主要关注核工业和科研等相关信息。被攻击目标主要集中在我国大陆境内。

该组织常使用鱼叉邮件作为主要攻击手段，通过向目标对象发送携带 LNK 文件和恶意 PowerShell 脚本诱导用户点击，窃取敏感文件，安装持久化后门程序，并使用如阿里云盘、新浪云等云服务，把窃取的数据托管在云服务上。由

于该组织相关恶意代码中出现特的字符串(Poison Ivy 密码是: NuclearCrisis), 结合该组织的攻击目标特点, 奇安信威胁情报中心将该组织攻击行动命名为核危机行动(Operation NuclearCrisis)。

2018 年期间, 该组织针对我国政府、军工、科研以及金融等重点单位和部门发起多次针对性攻击, 攻击手法相较于之前也有所升级, 并且鱼叉邮件携带恶意文件也由原本的恶意 PE 文件首次更新为 PowerShell脚本后门, 以及采用云空间、云附件的手法接收回传的资料信息等都反映了蓝宝菇APT组织在攻击技术方面的更新。

【近期攻击事件】

2018 年 4 月以来, 安全监测与响应中心和奇安信威胁情报中心在企业机构的协同下发现了一批针对性的鱼叉攻击, 攻击者通过诱导攻击对象打开鱼叉邮件云附件中的 LNK 文件来执行恶意 PowerShell 脚本收集上传用户电脑中的敏感文件, 并安装持久化后门程序长期监控用户计算机。该攻击过程涉及一些新颖的 LNK 利用方式, 使用了 AWS S3 协议和云服务器通信来偷取用户的敏感资料。

继披露了蓝宝菇 (APT-C-12) 攻击组织的相关背景以及更多针对性攻击技术细节后, 奇安信威胁情报中心近期又监测到该组织实施的新的攻击活动, 在 APT-C-12 组织近期的攻击活动中, 其使用了伪装成 "中国轻工业联合会投资现况与合作意向简介" 的诱导文件, 结合该组织过去的攻击手法, 该诱饵文件会随鱼叉邮件进行投递。

四、北美篇

// 9. Longhorn

【组织概述】

Longhorn 又名 Lamberts, APT-C-39 等。最早由国外安全厂商赛门铁克在 Vault 7 泄漏间谍工具后命名。Vault 7 是由维基解密从 2017 年 3 月起公布的一系列文件, 在这些文件中主要披露了美国中央情报局进行网络监控和网络攻击的活动与攻击工具。

据分析, Longhorn 至少从2011 年开始活动, Longhorn 感染了来自至少16 个国家包括中东、欧洲、亚洲和非洲等的 40 个目标, 主要影响金融、电信、能源、航空航天、信息科技、教育、和自然资源等部门。它使用了多种后门木马结合 0day 漏洞进行攻击。

奇安信威胁情报中心红雨滴团队对历史曝光的 CIA 网络武器及相关资料进行研究, 并发现了多种网络武器文件, 并且根据分析的结果与现有公开资料内容进行了关联和判定。

红雨滴团队还发现这些网络武器曾用于攻击中国的目标人员和机构, 其相关攻击活动主要发生在2012年到2017年(与 Vault 7 资料公开时间相吻合), 并且在其相关资料被曝光后直至2018年末, 依然维持着部分攻击活动, 目标可能涉及国内的航空行业。

【相关事件】

2019 年 9 月, 奇安信威胁情报中心红雨滴团队通过对曝光的 CIA 网络武器进行了国内安全事件的关联和判定, 发现这些网络武器曾用于攻击中国的人员和机构, 攻击活动主要发生在 2012 年到 2017 年(与Vault7资料公开时间相吻合), 并且在其相关资料被曝光后直至 2018 年末, 依然维持着部分攻击活动, 其目标涉及国内的航空行业。

2020年3月, 国内某安全厂商发布的报告表示, 中国航空航天、科研机构、石油行业、大型互联网公司以及政府机构等多个单位均遭到 Longhorn 不同程度的攻击。

攻击活动最早可以追溯到 2008 年 9 月，并一直持续到 2019 年 6 月。受害者主要集中在北京、广东、浙江等省市。该组织在针对中国航空航天与科研机构的攻击中，主要围绕系统开发人员来进行定向打击。这些开发人员主要从事的是航空信息技术有关服务，如航班控制系统服务、货运信息服务、结算分销服务、乘客信息服务等。攻击不仅仅是针对中国国内航空航天领域，同时还覆盖百家海外及地区的商营航空公司。

// 10. Crypto AG

【组织概述】

2020 年 2 月 11 日，《华盛顿邮报》联合德国电视二台 ZDF 曝光，CIA 一直利用顶级通信加密公司 Crypto AG 设备破解上百个国家政府数十年来的绝密信息。

【相关事件】

从上世纪60 年代开始，Crypto AG 的加密算法就被 NSA 操控，可以秘密的在加密设备中植入漏洞从而截取机密情报。

美国通过这种方式截取了大量秘密通信，包括其他 国家政府大量军事行动、人质危机、暗杀和爆炸事件的 通信。例如，在 1978 年美国前总统卡特与埃及前总统 萨达特举行埃及 - 以色列和平协议会谈时，美国能够监 听萨达特与开罗的所有通信；1979 年伊朗人质危机期间， CIA 和 NSA 也借此监听伊朗革命政府；在两伊战争的十 年时间里，美国甚至截获了19000 条加密机发送的伊朗情报。根据 CIA 的记录，在马岛战争期间，美国还利用阿根廷对于Crypto加密设备的依赖，将截获的阿根廷军事计划泄露给了英国。

目前有120 多个国家 / 地区购入过Crypto加密设备设备，客户包括伊朗、印度、巴基斯坦、拉丁美洲各国政府，甚至梵蒂冈。

// 11. Equation(方程式)

【组织概述】

2015 年，卡巴斯基揭露史上最强网络犯罪组织——Equation Group，该组织被视为隶属于美国情报部门 NSA 旗下，已活跃近 26 年，在攻击复杂性和攻击技巧方面超越历史上所有的网络攻击组织。根据卡巴斯基实验室目前所掌握的证据，Equation Group 被认为是震网(Stuxnet)和火焰(Flame)病毒幕后的操纵者。

从 2001 年至今，Equation 已在伊朗、俄罗斯、叙利亚、阿富汗、阿拉伯联合大公国、中国、英国、美 国等全球超过 30 个国家感染了 500 多个受害者。受害者包括政府和外交机构、电信行业、航空行业、能源行业、核能研究机构、石油和天然气行业、军工行业、 纳米技术行业、伊斯兰激进分子和学者、大众媒体、交 通行业、金融机构以及加密技术开发企业等。

【相关事件】

2017 年 4 月 14 日，“影子经纪人”曝光的数据中包含名为SWIFT 的文件夹，完整曝光了“方程式组织”对 SWIFT 金融服务提供商及合作伙伴的两起网络攻击行动：JEEPFLEA_MARKET 和JEEPFLEA_POWDER。

JEEPFLEA_MARKET 攻击行动是针对中东地区最大 SWIFT服务提供商 EastNets，成功窃取了其在比利时、约旦、埃及和阿联 酋的上千个雇员账户、主机信息、登录凭证及管理账号。

此次攻击以金融基础设施为目标，从全球多个区域的预设跳板机进行攻击。以0Day漏洞直接突破两层网络安全设备并植入持久化后门；通过获取内部网络拓扑、 登录凭证来确定下一步攻击目标；以“永恒”系列 0Day漏洞突破内网 Mgmt(管理服务器)、SAA业务服务 器和应用服务器，以多个内核级(Rootkit)植入装备向服务器系统植入后门；通过具

有复杂指令体系和控制功能的平台对其进行远程控制，在SAA业务服务器上执行SQL脚本来窃取多个目标数据库服务器中的关键数据信息。

JEEP FLEA_POWDER攻击行动是主要针对EastNets 在拉美和加勒比地区的合作伙伴 BCG (Business Computer Group)，但此次行动并未成功。

// 12、Sauron(索伦之眼)

【组织概述】

Sauron 被认为是与美国情报机构有关的组织，长期对中国、俄罗斯等国进行APT攻击，至少在 2011年10月起就一直保持活跃。以中俄两国的政府、科研机构、机场等为主要攻击目标。

Sauron使用恶意代码的难度和隐蔽性都与 APT 方程式相似，且与病毒火焰“Flame”有相似之处，被视为NSA 旗下黑客组织，与“方程式”实力相当。

【相关事件】

2016 年 8 月中旬，赛门铁克和卡巴斯基实验室相继发布报告称，追踪到名为 Sauron(Strider)的APT组织。赛门铁克发现，自 2011 年起，Sauron凭借 Backdoor.Remsec 恶意代码，攻击了中国、比利时、俄罗斯和瑞典的七个组织，包括位于俄罗斯的多个组织和个人、中国的一家航空公司、瑞典一个未公开的组织及比利时国内的一个大使馆。后门 Remsec 可以用来窃取Windows的用户信息，由 Lua 语言编写，模块化程度很高，不容易被发现。

目前，已知该组织攻击过的目标包括中国、俄罗斯、比利时、伊朗、瑞典、卢旺达等 30 多个国家，主要以窃取敏感信息为主要目的。主要针对国防部门、大使馆、金融机构、政府部门、电信公司以及科技研究中心等。

攻击所涉及的国内组织包括科研教育、军事和基础设施领域，重点行业包括水利、海洋等行业。除了政府机构与企业，他们还在公用网络中各种开后门，针对个人进行键盘监听、窃取用户凭证或密码等个人隐私信息。

结语

从2021年上半年发生的APT攻击活动可以看出，全球APT组织为达成攻击目的，不惜花费巨额资金和人力成本，比如，投入使用价值不菲的大量高价值0day漏洞等。

预计，APT组织在未来会继续使用更耗费资源且更先进的技术进行攻击，其中0day漏洞或是更为复杂的木马都将会频繁出现。

此外，APT攻击组织持续改进武器库，整体的威胁活跃水平保持相当高的频度，如毒云藤、蔓灵花、海莲花等国家级攻击组织，持续针对我国境内开展攻击活动。尤其是随着地缘政治紧张加剧，未来可能会出现更多利用APT组织刺探和窃取情报的攻击行动。对于APT组织威胁，绝不能放松警惕。

关于作者

奇安信集团红雨滴团队（RedDrip Team, @RedDrip7），依托全球领先的安全大数据能力、多维度多来源的安全数据和专业分析师的丰富经验，自2015年持续发现多个包括海莲花在内的APT组织在中国境内的长期活动，并发布国内首个组织层面的APT事件揭露报告，开创了国内APT攻击类高级威胁体系化揭露的先河。截至目前，持续跟踪分析的主要APT团伙超

过47个，独立发现APT组织14个，持续发布APT组织的跟踪报告超过90篇，定期输出半年和全年全球APT活动综合性分析报告。

本文首发于《网安26号院》，下载电子刊物，请点击[原文链接](#)。



奇安信威胁情报中心

威胁情报信息共享，事件预警通报，攻击事件分析报告，恶意软件分析报告
403篇原创内容



公众号

[阅读原文](#)